

UNIT-II

Planning and Implementation of an IT Infrastructure Audit for Compliance

1. Introduction to Planning an IT Infrastructure Audit

Before an IT audit is executed, the organization must conduct thorough planning to ensure:

- Audit objectives are clear
- Scope and boundaries are defined
- Resources and documentation are prepared
- Controls to be tested are identified
- Industry standards and compliance laws are mapped

The book emphasizes that **poor planning = poor audit results**, and proper planning is the foundation of an effective audit.

2. Defining the Scope of the Audit

(Directly from Chapter 4 content)

The **audit scope** defines:

- **What will be audited**
- **Which systems, locations, and domains**
- **Timeframe**
- **Compliance requirements**
- **Depth of testing**

A clearly defined scope prevents:

- Scope creep
- Missed areas
- Misuse of resources
- Incomplete or invalid audit findings

2.1 Components of Audit Scope

1. Organizational Requirements

Identify which functions, departments, or systems fall under the audit:

- Finance
- HR
- Operations
- IT department

2. Regulatory Requirements

Determine which regulations apply:

- ISO 27001
- COBIT
- SOC reporting
- HIPAA
- PCI DSS
- Indian IT Act

3. Technical Boundaries

Specify which IT assets are included:

- Servers
- Workstations
- Network devices
- Databases
- Applications
- Cloud environments

4. Physical Boundaries

Define office locations, data centers, and remote environments.

5. Processes to be Audited

Examples:

- Change management
- Patch management
- Access control
- Log management
- Backup & recovery

6. Timeframe

Audits may cover:

- Past 12 months
 - Current quarter
 - Current configuration baseline
-

3. Identifying Critical Requirements for the Audit

(From the book's audit planning methodology)

Critical requirements ensure the audit properly evaluates compliance.

3.1 Examples of Critical Requirements

1. Relevant Policies

- Information security policy
- Acceptable use policy
- Password policy
- Network security policy

Auditors must verify that policies **exist, are approved, and implemented.**

2. Regulatory Requirements

Each regulation has its own mandatory controls:

- PCI DSS → cardholder data protection

- HIPAA → health data confidentiality
- ISO 27001 → ISMS documentation & controls

The audit plan must **map each requirement** to the corresponding infrastructure domain.

3. Industry Standards

Auditors use frameworks to guide control evaluation:

- ISO 27002
 - COBIT 5 / COBIT 2019
 - NIST SP 800 series
-

4. Risk Assessment Results

Organizations conduct risk assessments before audits.

Auditors use the results to decide:

- Which systems are high-risk
 - Where controls must be tested more rigorously
 - Which vulnerabilities require attention
-

5. Documentation Requirements

Auditors must have access to:

- Network diagrams
 - Asset inventories
 - Configuration baselines
 - Security procedures
 - Change logs
 - Patch management reports
-

4. Assessing IT Security (Pre-Audit Assessment)

(Directly from book content — IT security posture evaluation)

Before the formal audit, an **IT security assessment** helps identify:

- Gaps in controls
- Missing documentation
- Potential compliance failures

This prepares the organization for a smoother, more successful audit.

4.1 Components of the Pre-Audit Security Assessment

1. Review of Controls

Ensure preventive, detective, and corrective controls exist.

2. Vulnerability Review

- Internal scans
- External scans
- Misconfigurations
- Weak passwords
- Missing patches

3. Policy Review

Ensuring policies match real-world implementations.

4. Configuration Review

Verifying that all systems follow secure configuration baselines:

- OS hardening
- Network device hardening
- Database security configuration

5. Interview Key Personnel

Assess understanding of:

- Roles
 - Responsibilities
 - Security processes
-

5. Obtaining Information, Documentation, and Resources

Auditors require **comprehensive access** to documentation and stakeholders.

5.1 Types of Required Information

1. Technical Documentation

- Network diagrams
- IP addressing
- VLAN mapping
- Firewall rule sets
- Router configurations
- System inventories

2. Security Documentation

- Policies
- SOPs
- Incident response procedures
- Change management records
- Backup logs
- Access control lists

3. Compliance Documentation

- Previous audit reports
 - Risk assessment results
 - Compliance certificates
-

6. Mapping the IT Security Policy Framework to the Seven Domains

(Book concept: map policies & controls to infrastructure domains)

The book presents a security policy framework that defines controls applicable to:

1. User Domain
 2. Workstation Domain
 3. LAN Domain
 4. LAN-to-WAN Domain
 5. WAN Domain
 6. Remote Access Domain
 7. System/Application Domain
-

6.1 Purpose of Mapping

Mapping ensures:

- Every domain has appropriate controls
 - No area is left unprotected
 - Policies align with technical implementation
 - Audit coverage is complete
-

6.2 Example of Mapping (Text-Based Diagram)

User Domain → AUP, RBAC, Password Policy

Workstation Domain → Hardening Policy, AV Policy

LAN Domain → NAC Policy, Segmentation Policy

LAN-to-WAN → Firewall Policy, IDS/IPS Policy

WAN Domain → Encryption Policy

Remote Access → VPN Policy, MFA Policy

System/Application → Patch Policy, Change Policy, Backup Policy

This mapping ensures structural auditing across all domains.

7. Identifying and Testing Monitoring Requirements

Monitoring requirements define **what must be observed, logged, measured, and verified** within the IT infrastructure to ensure compliance.

The book explains that monitoring is essential because **controls are not effective unless regularly tested and validated**.

7.1 Purpose of Monitoring Requirements

Monitoring ensures:

- Controls are functioning as intended
 - Compliance deviations are detected
 - Unauthorized activity is identified
 - Logs provide evidence for auditors
 - Security events trigger alerts
-

7.2 Monitoring Categories

1. Technical Monitoring

Checking configurations and events on:

- Firewalls
- Routers
- Switches
- Servers
- Applications
- Databases

Includes metrics such as:

- Failed logins

- Suspicious traffic
 - Configuration changes
 - Malware alerts
-

2. Administrative Monitoring

Monitoring:

- Policy violations
 - User training compliance
 - Access authorization approvals
 - Documentation updates
-

3. Physical Monitoring

Monitoring:

- CCTV logs
 - Access card usage
 - Server room entry logs
-

7.3 What Auditors Test in Monitoring

1. Log Generation

- Are logs enabled?
- Are logs capturing required events?

2. Log Integrity

- Are logs protected from modification?
- Are timestamps synchronized (NTP)?

3. Log Review Process

- Are logs reviewed daily/weekly?

- Are high-criticality systems monitored continuously?

4. Alerting Mechanisms

- Are alerts generated for unauthorized actions?
 - Are alerts documented & escalated?
-

7.4 Example (Non-case)

If password attempts exceed threshold:

- System must generate an alert
- Account must lock
- Event must be logged
- Admin must review the log

Auditors test all four steps.

8. What Are Controls and Why Are They Important?

Controls are **safeguards** used to reduce risk and enforce compliance.

The book emphasizes that controls are the **foundation** of IT risk management and compliance frameworks.

8.1 Types of Controls (Book-Aligned)

1. Preventive Controls

Stop incidents before they occur.

Examples:

- Firewalls
 - Password requirements
 - Access controls
 - Encryption
-

2. Detective Controls

Identify incidents after they occur.

Examples:

- IDS
 - Log monitoring
 - Integrity checks
-

3. Corrective Controls

Restore systems after an incident.

Examples:

- Backups
 - Patch application
 - System recovery tools
-

4. Deterrent Controls

Discourage unauthorized behavior.

Examples:

- Warning banners
 - Surveillance signs
-

5. Compensating Controls

Provide alternative protection when primary controls cannot be implemented.

9. Goal-Based Security Controls

Goal-based controls originate from **high-level security requirements**, such as:

- Protect confidentiality
- Protect integrity

- Maintain availability
- Ensure accountability

The book describes this as **top-down control design**: start from goals → map to policies → map to controls.

9.1 Examples of Goal-Based Controls

Goal: Protect Confidentiality

Controls:

- Encryption
 - Access control lists
 - Secure VPN
-

Goal: Protect Integrity

Controls:

- Hashing
 - Digital signatures
 - File integrity monitoring
-

Goal: Maintain Availability

Controls:

- Redundancy
 - UPS
 - Failover clusters
-

Goal: Ensure Accountability

Controls:

- Unique user IDs
 - Audit logs
 - Biometrics
-

10. Implementation-Based Controls

Implementation-based controls come from **specific technology or mechanisms**, not from high-level goals.

These controls are designed around:

- Platform requirements
 - Vendor recommendations
 - Hardware/software capabilities
 - System constraints
-

10.1 Examples of Implementation-Based Controls

1. Firewall Rulesets

The specific rules implemented may reflect:

- Business operations
 - Network segmentation
 - Vendor syntax
-

2. OS Hardening

Based on:

- Registry edits
 - File permissions
 - Local security policy
-

3. Database Configuration Controls

Such as:

- Query logging
 - Stored procedure restrictions
 - Access roles
-

4. Application Controls

Examples:

- Input validation
 - Session timeout
 - Password masking
-

11. The Security Control Formulation & Development Process

One of the most important topics in Unit-II.

The book outlines a **structured process** for developing controls systematically.

11.1 Steps in Designing Security Controls

Step 1 — Identify Business & Compliance Requirements

Determine what must be protected and why.

Examples:

- PCI DSS → protect cardholder data
 - ISO 27001 → protect all information assets
-

Step 2 — Identify Risks

Use risk assessments to understand:

- Threats

- Vulnerabilities
- Impact
- Likelihood

This guides control prioritization.

Step 3 — Select Appropriate Controls

Controls may be selected from:

- ISO 27002 Annex A controls
- NIST SP 800-53 controls
- COBIT control objectives

Controls must be:

- Appropriate
 - Cost-effective
 - Scalable
 - Mapped to compliance needs
-

Step 4 — Develop Control Implementation Requirements

Define how controls will be implemented.

Example:

If the policy says “Encrypt sensitive data,”
implementation defines:

- AES-256 standard
 - Key rotation every 90 days
 - Hardware security module (HSM) storage
-

Step 5 — Document Controls

Control documentation includes:

- Description
- Purpose
- Owner
- Procedure
- Evidence requirements

Documentation is essential for audits.

Step 6 — Test Controls

Auditors validate control effectiveness through:

- Log review
 - Interviews
 - Testing configurations
 - Reviewing system outputs
-

Step 7 — Monitor & Improve

Controls must be monitored and updated to remain effective.

The book emphasizes that **control lifecycle is continuous**, not one-time.

12. Setting the Stage for Control Implementation Through Security Architecture Design

(From book's section on security architecture & control alignment)

Security architecture defines the **overall structure of security controls** across the organization.

It establishes *how* and *where* controls will be applied.

The book emphasizes that **security architecture must be aligned with:**

- Business goals
- Risk assessment results
- Regulatory requirements

- Technical capabilities
 - Organizational policies
-

12.1 Purpose of Security Architecture in an Audit

Security architecture:

- Ensures consistency in control implementation
 - Helps auditors map controls to systems
 - Reduces complexity during audits
 - Ensures policies are enforced across all domains
 - Provides a blueprint for evidence collection
-

12.2 Components of Security Architecture (Book-Aligned)

1. Policy Framework

- Information Security Policy
- Domain-specific policies
- Technical standards
- Procedures

2. Security Domains

Mapped to the seven IT infrastructure domains from Unit-I.

3. Control Layers

Controls are placed in:

- Network layer
- Application layer
- Host layer
- Data layer
- Physical layer

4. Trust Zones

Security architecture defines separate trust levels for:

- Internal network
- DMZ
- External networks
- Remote users

5. Control Inheritance

Some controls apply broadly (e.g., authentication), while others are domain-specific (e.g., firewall rules).

12.3 Example (Non-case)

If the architecture requires all sensitive data to be encrypted at rest:

- Database servers → full-disk encryption
- Backup tapes → encryption
- File servers → volume encryption
- Keys → managed via HSM

Auditors verify each implementation against policy.

13. Implementing a Multitiered Governance & Control Framework

(Directly from book's governance and layered control model)

A **multitiered framework** ensures controls are applied consistently across the entire organization.

13.1 Tiers in Governance & Control Framework

Tier 1 — Enterprise-Level Governance

Focuses on:

- Corporate policies

- Risk appetite
- Compliance requirements
- Governance committees
- Management accountability

Tier 2 — Process-Level Controls

Includes:

- Change management
- Incident response
- Patch management
- Configuration management

These controls ensure IT processes operate securely.

Tier 3 — Technical Controls

- Firewalls
- Encryption
- Logging
- Authentication
- Access controls

These are aligned with architecture and technical standards.

13.2 Why Multitiered Governance is Needed

Because:

- Different systems have different risks
- Controls must remain consistent and auditable
- Policies must map down to procedures and implementations
- Audit coverage improves when controls exist at every layer

14. The IT Audit Process

(From book's audit methodology framework)

The audit process includes **three major phases**:

✓ **Audit Planning**

✓ **Audit Fieldwork (Execution)**

✓ **Audit Reporting & Follow-up**

14.1 Audit Plan

The audit plan defines **how the audit will be performed**.

Key components of an audit plan:

1. Objectives

- What is the audit intended to verify?

2. Scope

- Systems, domains, locations, processes included.

3. Audit Criteria

- Policies
- Standards (ISO, COBIT, NIST)
- Regulations

4. Methodology

- Interviews
- Log analysis
- Control testing

5. Resources Needed

- Auditors
- Subject matter experts

- Tools

6. Timeline & Milestones

7. Deliverables

- Audit report
- Corrective action list

15. Types of IT Audits

(Book content from early chapters)

The book categorizes IT audits into several types:

1. General Controls Audit

Evaluates high-level IT controls:

- Governance
- Policy
- Access control
- Change management

2. Application Controls Audit

Evaluates controls within applications:

- Input validation
- Processing accuracy
- Output accuracy
- Error handling
- Logging

3. Operational Audit

Reviews operational processes:

- Backup operations
- Scheduling

- Capacity management
- Physical security

4. Compliance Audit

Checks adherence to:

- Standards
- Regulations
- Internal policies

5. Technical/Configuration Audit

Deep technical assessment of:

- Routers
- Switches
- Firewalls
- Servers
- Databases

16. Computer-Assisted Audit Techniques (CAATs)

(Major syllabus topic, directly from chapter content)

CAATs are software tools and techniques that help auditors:

- Collect evidence
- Analyze data
- Test controls
- Automate audit processes

16.1 Why CAATs Are Needed

Because IT environments contain:

- Massive amounts of data

- Complex technology
- Distributed systems

Manual review is insufficient or impossible.

16.2 Types of CAATs (Book-Aligned)

1. Data Extraction Tools

Used to pull data from:

- Databases
- Applications
- Logs

Examples:

SQL queries, log parsers.

2. Data Analysis Tools

Perform:

- Sorting
- Sampling
- Correlation
- Trend analysis

Example:

Detecting repeated failed login attempts over time.

3. Automated Testing Tools

Used for:

- Configuration scanning
- Patch verification
- Password testing

- File integrity checking
-

17. CAATs for Sampling

Sampling is used when the auditor cannot review full datasets.

Methods:

1. Random Sampling

Randomly chosen entries from a full dataset.

2. Systematic Sampling

Select every *n*th entry.

3. Stratified Sampling

Divide data into categories and sample from each.

4. Judgment Sampling

Auditor selects samples based on risk.

What CAATs Do in Sampling

- Automatically generate randomized sample lists
 - Extract matching records
 - Tag exceptions
 - Provide audit trails
-

18. CAATs for Application Reviews & Application Control Auditing

Applications contain both **functional** and **security** controls.

CAATs help auditors verify:

1. Input Controls

- Input validation
- Field length checks

- Format checks
- Mandatory fields

2. Processing Controls

- Correct calculations
- Exception handling
- Workflow integrity

3. Output Controls

- Report accuracy
- Proper formatting
- No unauthorized information included

4. Logging & Monitoring

CAATs verify that logs are:

- Complete
- Accurate
- Secure
- Reviewed

19. CAATs for Auditing Application Controls (Detailed – Book-Aligned)

Application controls ensure that business applications process data:

- Accurately
- Completely
- Securely
- According to policies and regulations

CAATs help auditors validate **each category** of application controls.

19.1 Types of Application Controls (per book)

✓ **Input Controls**

✓ **Processing Controls**

✓ **Output Controls**

✓ **Integrity Controls**

✓ **Security Controls**

CAATs automate testing of these controls.

19.2 CAATs for Input Controls

Input controls ensure only valid, authorized, and correctly formatted data enters the system.

CAATs test input controls by:

1. Extracting input logs
2. Identifying invalid or incomplete entries
3. Checking for missing mandatory fields
4. Detecting input errors due to poor validation
5. Checking user actions for unauthorized data entry

Examples tested by CAATs:

- Username length greater than allowed
- Invalid date formats
- Input fields left blank
- Unauthorized user submitting input

19.3 CAATs for Processing Controls

Processing controls check that the system processes data correctly.

CAATs validate:

- Calculations

- Workflow steps
- Batch processing integrity
- Transaction completeness

Examples:

- Verifying that a payroll calculation formula is implemented correctly
 - Checking that batch processes do not skip records
 - Identifying duplicate transactions
-

19.4 CAATs for Output Controls

Output controls verify that system outputs:

- Are accurate
- Reach the right people
- Do not leak sensitive data

CAATs help auditors:

- Recalculate outputs to confirm accuracy
 - Compare system output to expected values
 - Identify anomalies in reports
 - Flag missing or unauthorized output
-

19.5 CAATs for Integrity Controls

Integrity controls ensure:

- No unauthorized data modification
- Proper error detection and correction
- Data consistency between modules

CAATs test integrity controls by:

- Checking for broken relationships in database tables

- Detecting unauthorized changes
 - Verifying timestamps
 - Analyzing record history
-

19.6 CAATs for Application Security Controls

These include:

- Authentication
- Authorization
- Session management
- Access policies

CAATs test:

- Login attempt logs
 - MFA logs
 - Password policy compliance
 - Privilege escalations
 - Unauthorized access attempts
-

20. Mapping Security Controls to Audit Objectives

(Extremely important for NFSU exams)

Auditors must map **each audit objective** to the **control** that enforces it.

20.1 Steps in Mapping Controls

1. Identify Audit Objective

Example: “Verify workstation domain compliance.”

2. Identify Relevant Controls

- Patch management

- Antivirus
- USB restrictions

3. Identify Implementation Artifacts

Evidence includes:

- Patch logs
- AV console reports
- Group policy details

4. Identify Testing Method

Use:

- Log review
- Configuration scanning
- Interviews

5. Document Mapping

Auditors must map objectives → controls → evidence clearly.

21. Evaluating Access Controls (Technical Audit Focus)

Access control evaluation is one of the **core components** of IT audits.

21.1 Types of Access Controls Auditors Test

1. Physical Access

- Server room restrictions
- Entry/exit logs

2. Logical Access

- Authentication methods
- Authorization rules
- Privilege levels

3. Administrative Access

- Admin account management
 - Privilege segregation
 - Role-based access
-

21.2 How Auditors Evaluate Access Controls

Step 1 — Review Access Policies

Check:

- Password policy
- RBAC model
- MFA requirements

Step 2 — Review Access Lists

Look at:

- OS permission lists
- File system ACLs
- Database roles

Step 3 — Use CAATs for Verification

CAATs help auditors identify:

- Dormant accounts
- Excess privileges
- Orphan accounts (no owner)
- Accounts with expired credentials
- Accounts never used

Step 4 — Validate User Life Cycle

Check the process of:

- User onboarding

- Role changes
- Account termination

Step 5 — Test Privileges

Auditors may attempt:

- Least privilege verification
 - Segregation of duties checks
-

22. Evaluating Configuration Compliance

Configuration compliance ensures systems adhere to:

- Policies
 - Baselines
 - Secure configuration standards
-

22.1 What Auditors Review

1. Configuration Baselines

Defined for:

- OS
- Servers
- Network devices

2. Hardening Guidelines

- Disable unused services
- Block unused ports
- Apply secure defaults

3. Patch Levels

Audit verifies:

- OS patches

- Firmware updates
- Application patches

4. Change Management Records

Every change must be:

- Documented
 - Approved
 - Tested
 - Logged
-

22.2 How CAATs Help

CAATs can:

- Scan devices for missing patches
 - Compare configs against baseline
 - Detect unauthorized configuration changes
 - Report deviations automatically
-

23. Evaluating Logging & Monitoring Controls

Logging is essential for:

- Detecting attacks
 - Investigating incidents
 - Supporting audit trails
-

23.1 Audit Objectives for Logs

1. Completeness

Are all required events logged?

2. Protection

Are logs tamper-proof?

3. Review

Are logs reviewed periodically?

4. Retention

Are logs stored for required duration?

5. Alerts

Are alerts generated for critical events?

23.2 What CAATs Test

- ✓ Detect missing log entries
 - ✓ Detect abnormal activity
 - ✓ Detect inconsistent timestamps
 - ✓ Verify log forwarding (SIEM integration)
 - ✓ Identify devices not sending logs
-

24. Collecting Audit Evidence

Evidence supports audit findings and must be:

- ✓ Reliable
 - ✓ Observable
 - ✓ Measurable
 - ✓ Verifiable
-

24.1 Types of Audit Evidence (Book-Aligned)

1. Physical Evidence

- Photos of server racks

- Access badge entry logs

2. Documentary Evidence

- Policies
- Standards
- Procedures

3. Testimonial Evidence

- Interviews
- Confirmations
- Attestations

4. Analytical Evidence

- Log correlations
 - Trend analysis
 - CAAT-generated reports
-

25. Documenting Audit Findings

Audit findings must:

- ✓ **Identify the issue**
 - ✓ **Reference criteria or standard violated**
 - ✓ **Describe evidence**
 - ✓ **Explain risk or impact**
 - ✓ **Provide recommendations**
 - ✓ **Assign priority**
-

25.1 Structure of Audit Findings (Professional Format)

1. Finding Title

2. **Description of Issue**
3. **Associated Risk**
4. **Criteria Violated**
5. **Evidence Collected**
6. **Root Cause**
7. **Recommendation**
8. **Management Response**
9. **Action Plan**

This format is directly aligned with standard IT audit frameworks.

26. COMPLETE UNIT-II SUMMARY (BOOK-ALIGNED)

Unit-II focuses on **how to plan, structure, and execute an IT infrastructure audit**.

It covers everything from defining scope → control selection → testing → CAATs → audit reporting.

This summary consolidates all topics from Parts 1–4.

26.1 Planning an Audit

1. Defining Audit Scope

Scope determines what is included/excluded in the audit:

- Systems
- Processes
- Locations
- Compliance requirements
- Domains
- Timeframe

2. Identifying Critical Requirements

This includes:

- Internal policies
- Regulatory standards
- Risk assessment results
- Documentation requirements

3. Pre-Audit IT Security Assessment

Assess controls, configurations, vulnerabilities, and gaps before formal audit.

26.2 Obtaining Information, Documentation & Resources

Auditors require:

- Policies
- Standards
- Procedures
- Network diagrams
- Asset inventories
- System baselines
- Change logs
- Risk assessment reports

These documents are used to evaluate compliance.

26.3 Mapping IT Security Policies to the Seven Domains

Domains include:

1. User
2. Workstation
3. LAN
4. LAN-to-WAN
5. WAN

6. Remote Access

7. System/Application

Mapping ensures **complete audit coverage**.

26.4 Identifying & Testing Monitoring Requirements

Auditors verify:

- Logging
- Alerting
- Monitoring controls
- Log integrity
- Log review processes
- Alert escalation procedures

Three categories:

- Technical
 - Administrative
 - Physical
-

26.5 Security Controls and Their Importance

Controls reduce risk and ensure compliance.

Types:

- Preventive
 - Detective
 - Corrective
 - Deterrent
 - Compensating
-

26.6 Goal-Based vs Implementation-Based Controls

Goal-Based Controls:

Derived from:

- CIA triad
- Business goals
- Compliance objectives

Implementation-Based Controls:

Derived from:

- Technology
 - Platform
 - Vendor recommendations
-

26.7 Control Formulation & Development Process

Steps include:

1. Identify compliance requirements
 2. Identify risks
 3. Select controls
 4. Define implementation details
 5. Document controls
 6. Test controls
 7. Monitor & improve
-

26.8 Security Architecture Design & Audit Preparation

Architecture establishes:

- Control layers
- Trust zones

- Domain-specific control mapping
- Standardized implementation

Auditors use architecture to evaluate consistency.

26.9 Multitiered Governance & Control Framework

Three tiers:

1. Enterprise governance
2. Process controls
3. Technical controls

Governance ensures accountability, consistency, and compliance.

26.10 IT Audit Process

Three phases:

1. Audit Planning

- Scope
- Objectives
- Criteria
- Methodology

2. Audit Fieldwork

- Evidence collection
- Testing
- Analysis

3. Audit Reporting

- Findings
- Recommendations
- Corrective actions

26.11 CAATs (Computer-Assisted Audit Techniques)

CAATs help with:

- Data extraction
- Data analysis
- Configuration scanning
- Monitoring
- Sampling
- Application control validation

CAATs are used for:

- Input controls
- Processing controls
- Output controls
- Security controls
- Integrity controls

27. IMPORTANT TABLES & DIAGRAMS

27.1 Audit Planning Process Diagram

Define Scope

↓

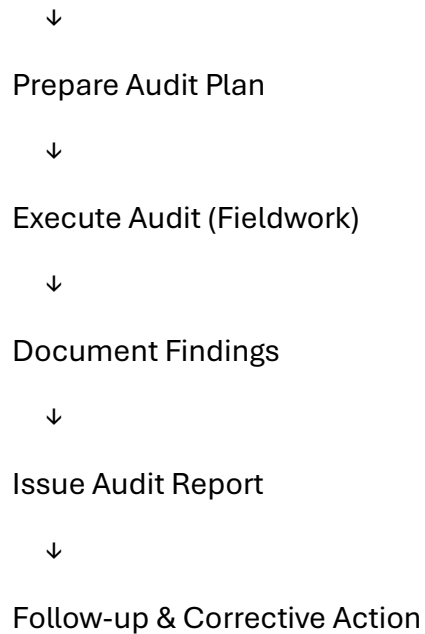
Identify Requirements

↓

Gather Documentation

↓

Map Controls to Domains



27.2 Goal-Based vs Implementation-Based Controls Table

Control Type	Source	Examples
Goal-Based	CIA triad, business needs	Encryption, RBAC, MFA
Implementation-Based	Technology/vendor-specific	Firewall rules, OS hardening, DB roles

27.3 Evidence Types Table

Evidence Type	Description	Examples
Physical	Tangible observations	Server room photos
Documentary	Written policies & logs	Access control lists
Testimonial	Interviews	Admin explanations
Analytical	Data-based	Log correlations

27.4 Audit vs Monitoring vs Assessment Table

Activity	Purpose	Frequency	Performed By
Audit	Validate compliance	Annual	Independent auditors
Assessment	Identify weaknesses	Periodic	Internal teams
Monitoring	Detect events	Continuous	SOC, admins
